

Assessment Report on the [REDACTED] Network

I. Executive Summary

TTG was engaged to conduct an independent, outside review of the [REDACTED] IT network and associated practices. The project was intended to identify specific potential risks, as well as actionable steps accounting for risk level and current service needs. These steps will assist [REDACTED] in ensuring that the network follows generally accepted practices in keeping network data and network access secure.

In early December 2018, TTG ran an automated scan of the [REDACTED] network using a commercially available network assessment tool. Portions of the scan were re-run in mid-February 2019 to account for network changes in the interim. Subsequent to both scans, TTG staff reviewed the considerable data that was generated, and then identified and prioritized recommended actions.

With one exception, the scan identified issues that can be largely addressed by implementing technology policy changes. The exception deals with [REDACTED] user credentials being found on the Dark Web. Issues related to passwords/credentials continues to be a significant security risk and should be addressed. The recommendations and specific suggested actions from the scan are discussed in the Section III of this report. The risks are identified, explained and supporting materials for follow up are provided, including the specific user accounts/machines affected, where possible.

In addition to the automated scan, there were numerous documents to be reviewed as part of an overall assessment effort. Due to [REDACTED] acquisition activities, TTG was not able to obtain these documents, but would still like to review them as they may require additional recommendations. These specific desired materials are listed later in this document.

TTG is prepared to work with [REDACTED] on the implementation the recommendations in this report.

II. Approach Used for the Project

There were two major components to the project:

1. Automated Data Scan
2. Review of Documents and Materials

Automated Data Scan – In December, 2018 TTG ran a network scan on the [REDACTED] network. The network was accessed with permission from TTG's offices in Dublin, OH. The scan was updated in February 2018. The scan was conducted using Network Detective, a common and non-invasive network data collection tool that is a generally accepted toolset for these purposes. The scan was performed

Assessment Report on the [REDACTED] Network

based on network information provided by [REDACTED]. Scans were conducted on approximately two dozen network locations covering approximately 35,000 IP addresses.

The scan conducts a series of Discovery tasks and searches for dozens of potential issues across the network. These discovery tasks are shown in Exhibit 1 – Discovery Tasks Performed.

The scan results were converted into various reports, several of which are provided as attachments to this document. The raw reports were further reviewed by TTG staff to review the tool outputs. TTG then confirmed priorities and recommended actions based on its experience and similar reviews conducted. TTG's specific recommendations are included later in this report.

It should be noted that with respect to scanning, the tool returned information on items discovered *at the time the scan was run*. Devices that were turned off or otherwise inaccessible, are not included in the results, nor are devices or locations added since the scan was run.

With respect to additional network sites added since the automated scan was conducted, it is our understanding that these sites have been installed with new equipment and will follow the same network rules and policies as existing [REDACTED] sites. Therefore, all practice and policy recommendations would be the same.

Exhibit 1 – Discovery Tasks Performed

The following discovery tasks were performed.

Assessment Report on the [REDACTED] Network

III. Identified Issues and Recommendations Based on Automated Data Scan

A. High-Risk Issues – Immediate Action Required

1. Compromised Passwords found on Dark Web

Issue: A scan of the Dark Web revealed multiple compromised passwords from the [REDACTED] domain. The most recent compromises occurred in 2018, so these are recent, even more so than data previously informally provided to [REDACTED] in the summer of 2018. A sample of password information for five accounts found is shown in the table below:

Email	Password	Compromise Date	Source
[REDACTED]	Mykid*****	23-Mar-2018	id theft forum
[REDACTED]	Sanch*****	23-Mar-2018	id theft forum
[REDACTED]	Famil*****	23-Mar-2018	id theft forum
[REDACTED]	bball*****	27-Jan-2017	id theft forum
[REDACTED]	Digge*****	23-Mar-2018	id theft forum

Recommendations:

- Ensure the compromised passwords are no longer in use. We recommend having **all** users reset their password as the extent of the compromise is difficult to assess.
- Implement proactive Dark Web Monitoring and Alerting so that ongoing compromises may be more rapidly identified and addressed.
- Ensure all employees **take** (not just have access to) training in basic password, email phishing, and computer security practices.
- Implement weekly proactive “push” communications, including micro training, to all employees.

Assessment Report on the [REDACTED] Network

2. User Passwords Set Never to Expire

Issue: User accounts with passwords set to never expire present a risk of use by unauthorized users. They are more easily compromised than passwords that are routinely changed. Changing passwords regularly is particularly important given the knowledge that user credentials have been compromised per the previous issue item. Non-expiration of passwords was discovered on 468 accounts in the most recent scan. These specific accounts are listed in the Consolidated Management Plan Report which is attached.

Recommendation: Investigate all accounts with passwords set to never expire and configure them to expire regularly.

We do recognize there might be resistance to this change at some levels of the organization. We can explore alternatives, where appropriate, to password expiration with you, such as more complex passwords and/or pass phrases.

3. Password History not remembered

Issue: While it is important to change passwords, it is not unusual for users to attempt to recycle/reuse a small set of the same account passwords over and over. The continual reuse of passwords defeats the effectiveness of a good password management policy. Windows Active Directory can remember a user's previously used password history and can be set to disallow recently used passwords on an account.

Recommendation: Increase password history to remember at least the last six previously used passwords. Understanding that this restriction can be a burden to certain users, the organization may wish to investigate the use of Password Management tools to reduce the number of passwords than a user must remember and/or more complex pass phrases.

4. Various System Update Issues

Issue: There were three issues identified related to system updates:

- a. Excessive Security Patches Missing on Computers (1 instance)
- b. Anti-Virus Not Installed (2 instances)
- c. Anti-Spyware Not installed (2 instances)

Maintaining up to date patches and security software is critical to preventing unauthorized access and the spread of malicious software. While this is considered a High-Risk item, it is relevant to note that this was not observed to be widespread. The results changed from the December scan to the February scan and may suggest that these conditions are

Assessment Report on the [REDACTED] Network

transient.

Recommendation:

- A. This observation may have been an anomaly based on when the scan was run. However, it is important to ensure that patching and updates follow a regular process and is not done randomly. Ensure that [REDACTED] Managed Services Provider has set a formal schedule for updates, has a process for dealing with exceptions, and is producing regular reporting that demonstrates compliance.

Note that the server [REDACTED] was the device missing security matches and this should be addressed immediately.

Complete results can be found in the Comprehensive Management Plan.

B. Medium-Risk Issues

5. Users Not Logged on in 30 Days

Issue: Users have not logged on to domain in 30 days (as of the scan date). A user that has not logged in for an extended period of time is likely a former employee or vendor. While not a significant risk in small numbers, this issue was observed 498 times and as such, these credentials should be removed. A complete list of accounts can be found in the Consolidated Management Plan Report. After review by [REDACTED], we can do further analysis if needed.

Recommendation:

- A. Disable or remove user accounts for users that have not logged on to active directory in 30 days.
- B. Add a procedure to the employee offboarding process to include the removal of account credentials.

6. Operating Systems in Extended Support

Issue: Computers are using a Microsoft operating system that is in Extended Support, specifically Windows 7 & 8 and Windows Server 2003 & 2008. Extended Support is a warning period before an operating system is no longer supported by the manufacturer and will no longer receive support or patches. These 123 computers are listed in the

Assessment Report on the [REDACTED] Network

Consolidated Management Plan Report.

Recommendation: These devices should be flagged for updating as part of the ongoing equipment refresh process currently being undertaken. Upgrade/replace computers that have operating systems in Extended Support before end of life.

Note that it is possible that some of these devices may already have been taken out of service.

7. Inactive Computers

Issue: Related to the item above, numerous computers have not checked in during the past 30 days (as of the scan date). While not an inherently large risk by itself, a total of 106 devices were observed with this condition. Most likely these are machines that have been retired or are otherwise not assigned to active users. The specific computers are listed are included in the Consolidated Management Plan Report.

Recommendation:

- A. Investigate the list of inactive computers and determine if they should be removed from Active Directory, rejoined to the network, or powered on.
- B. Add a procedure to the equipment replacement process to remove machines from Active Directory when retired or replaced.

8. Automatic Screen Lock not turned on.

Issue: Automatic screen lock prevents unauthorized access when users leave their computers. Having no screen lock enabled allows unauthorized access to network resources. While only a single device was observed with this condition, it was the server [REDACTED] and it should be secured.

Recommendation: Enable automatic screen lock on the specified devices listed in the Consolidated Management Plan

9. Access to Undesirable Sites on 1 Server.

Issue: One report appears to show access to undesirable website categories (e.g. pornography) from the server [REDACTED]. It does suggest that the [REDACTED] configuration should be reviewed.

Details can be found on the Outbound Security Report, provided on the USB flash drive.

Assessment Report on the [REDACTED] Network

Recommendation: Review external web filtering settings for the network and devices.

Assessment Report on the [REDACTED] Network

C. Lower Risk Issues to be addressed

These issues are not “urgent” but should be address as part of ongoing support for a secure and well-functioning network.

10. Un-populated Organization Units

Issue: A total of 60 empty organizational units (OU) were found in Active Directory. These may not be needed and can lead to misconfiguration. These are listed in the Consolidated Management Plan Report.

Recommendation: Remove or populate empty organizational units.

11. Insecure Listening Ports

Issue: Computers are using potentially insecure protocols (FTP, SMTP, SSH, Telnet, etc.). There were 2 instances of this and the affected machines are listed in the Consolidated Management Plan Report. This is not uncommon, and we consider this to be a low risk item

Recommendation: There may be a legitimate business need, but these risks should be assessed individually. Certain protocols are inherently insecure since they often lack encryption. Inside the network, their use should be minimized as much as possible to prevent the spread of malicious software. Of course, there can be reasons these services are needed and other means to protect systems which listen on those ports. We recommend reviewing the programs listening on the network to ensure their necessity and security

Assessment Report on the [REDACTED] Network

12. Potential Personally Identifiable Information (PII) on network shares

Issue: The initial scan detected a single instance of PII on one machine. This did not show up on the second scan and we believe it may have been a cached copy of a deleted document. This is positive outcome.

Details are provided in the Data Breach Security Report provided on the USB Flash Drive.

Recommendation: Because of the sensitivity of PII, we believe that a periodic rescan would help ensure the protection of sensitive data.

Assessment Report on the [REDACTED] Network

IV. Additional Materials to Review and Other Remaining Steps

In addition to the Network Scan, TTG discussed various materials with the [REDACTED] staff in December. At that time numerous materials were still under development and shortly thereafter, TTG was asked to pause while acquisition activities were underway.

It would be beneficial to receive copies of the following materials if they exist, primarily in the areas of policies and procedures which are also germane to the assessment as they might indicate additional strengths or areas for improvement in terms of network management and security.

Specific items needed for review are:

- 1. Existing IT-specific Policies**
- 2. Disaster Recovery and Business Continuity Plans**
 - a. Emergency Operations**
 - b. Data Backup and Restoration**
 - c. Redundancy plans**
- 3. HIPAA Compliance Plan**
- 4. Encryption Policies**
- 5. Cyber Liability Insurance Policies**
- 6. Any other related IT documentation**
- 7. Vendor Agreements / SLAs / Business Review materials**
 - These would be reviewed to identify IT support process risks
- 8. Data Center Firewall Rules**
 - TTG will need assistance in gaining access

If the above do not exist or have not been completed, TTG can assist with their development.

Assessment Report on the [REDACTED] Network

V. Possible Areas for Further Assistance

During discussions with TTG in December, several other areas were identified for possible further review and action. While outside the scope of a typical network and security assessment, TTG is willing to assist [REDACTED] in these areas and can provide a proposal to conduct this work. These areas include:

- 1. A review of the Mail filtering configuration – Microsoft Advanced Threat Protection (ATP)**
- 2. A review of the DNS filtering configuration – Cisco Umbrella**
- 3. A review of the configuration of A/V tools - Webroot**
- 4. An assessment of how printers/scanners may be configured to store image information locally on devices**
- 5. A review of eFax procedures**
- 6. An audit of document disposal practices at all locations**
- 7. Identification of rogue software.**
- 8. A review of the Business Intelligence Environment**